Cyberdefense

The Never-Implemented Story of Penetration Tests on Video Surveillance Networks

Claire Vacherot

SECURITY FEST

whoami

Claire Vacherot

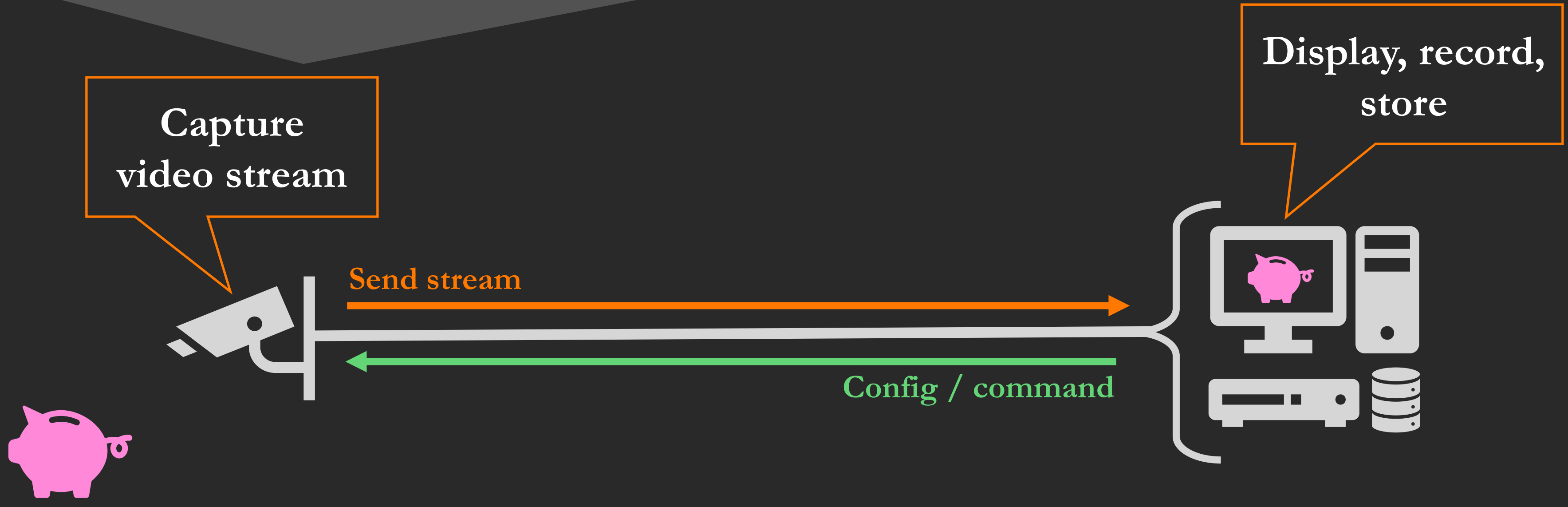
Senior pentester @ Orange Cyberdefense, France

Industrial networks and devices security

Penetration tests on OT networks

Speaker @ GreHack, DEF CON, Hack.lu

Video surveillance systems

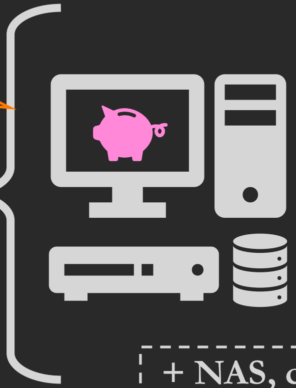


Components

Cameras, intercoms

VMS
(Video Management System)

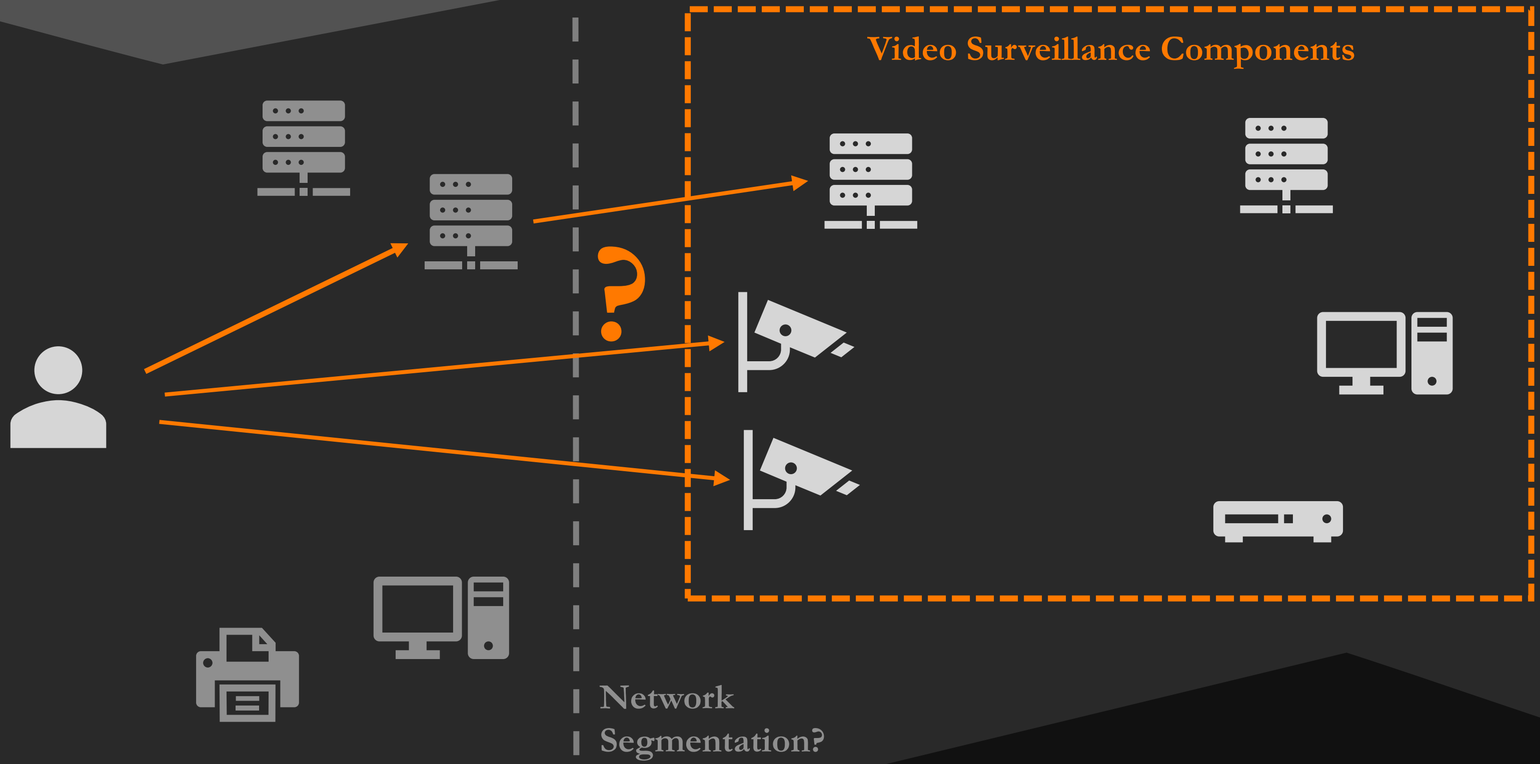
Contributors to Specification v1.0
Axis, Pelco, Anixter, Avigilon, Bosch, Canon, Genetec, Hanwha, Oncam, Panasonic, Sony, Videotec



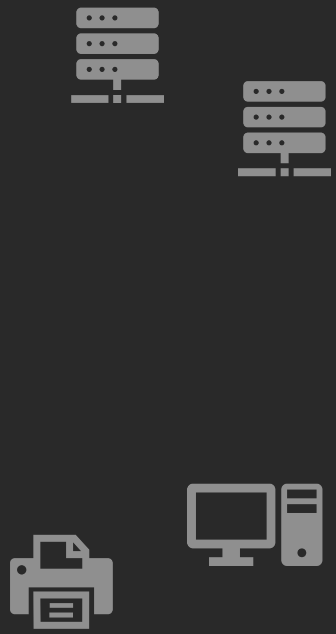
NVR (Network Video Recorders)
XVR, DVR

+ NAS, converters, encoders, etc.

The pentester’s view

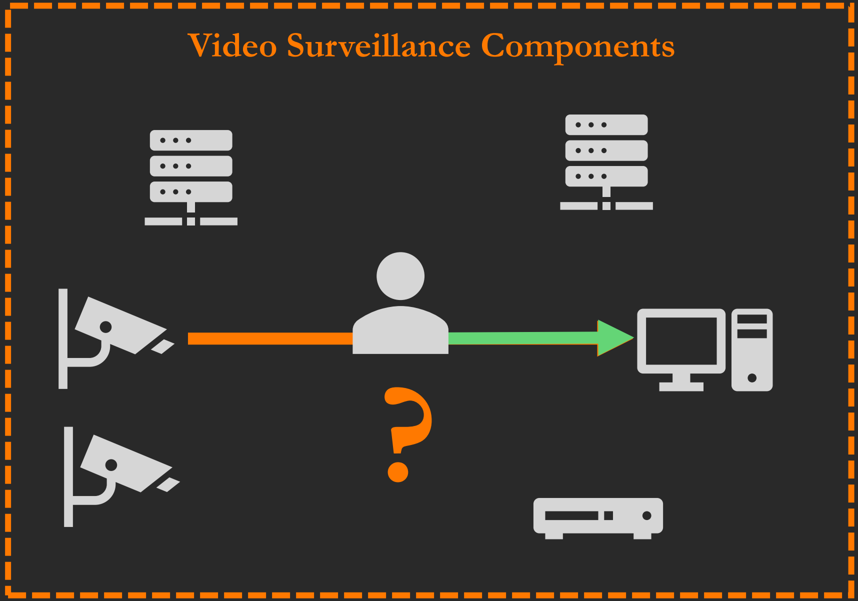


The pentester's view



Network
Segmentation?

The pentester’s view



Do not do this in sensitive environments

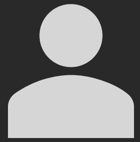
Find video surveillance components

Initial access

Fun with video streams

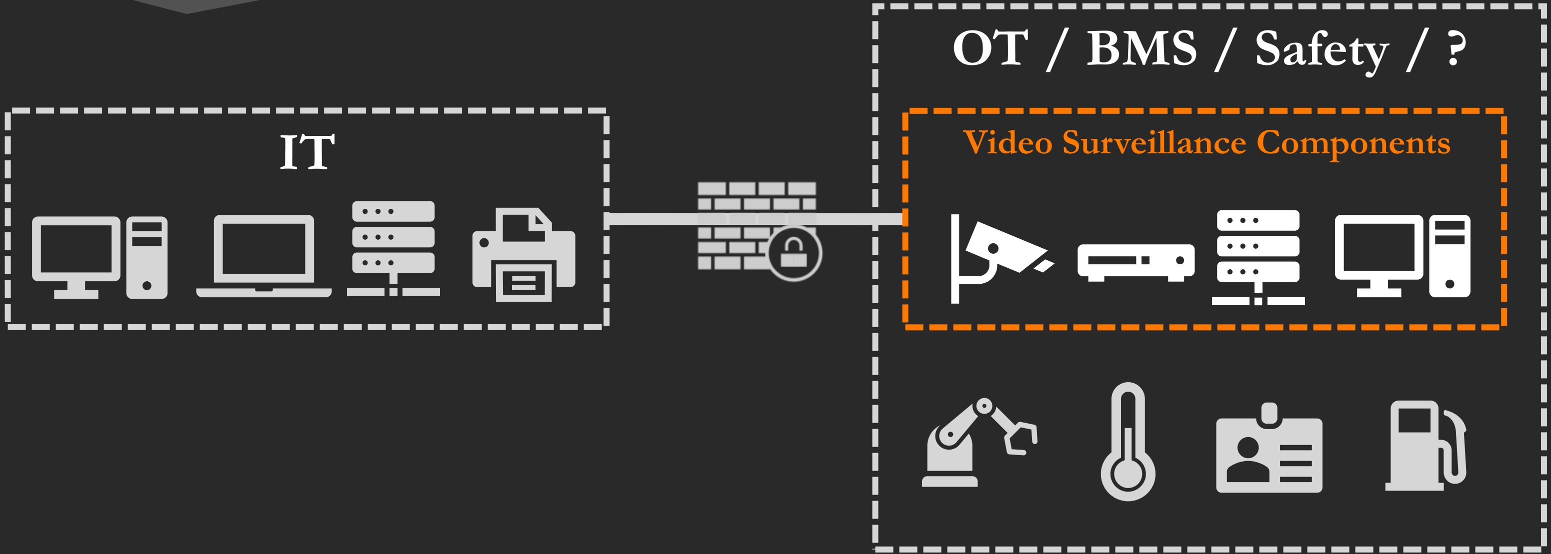
Reconnaissance

Where video
surveillance ??

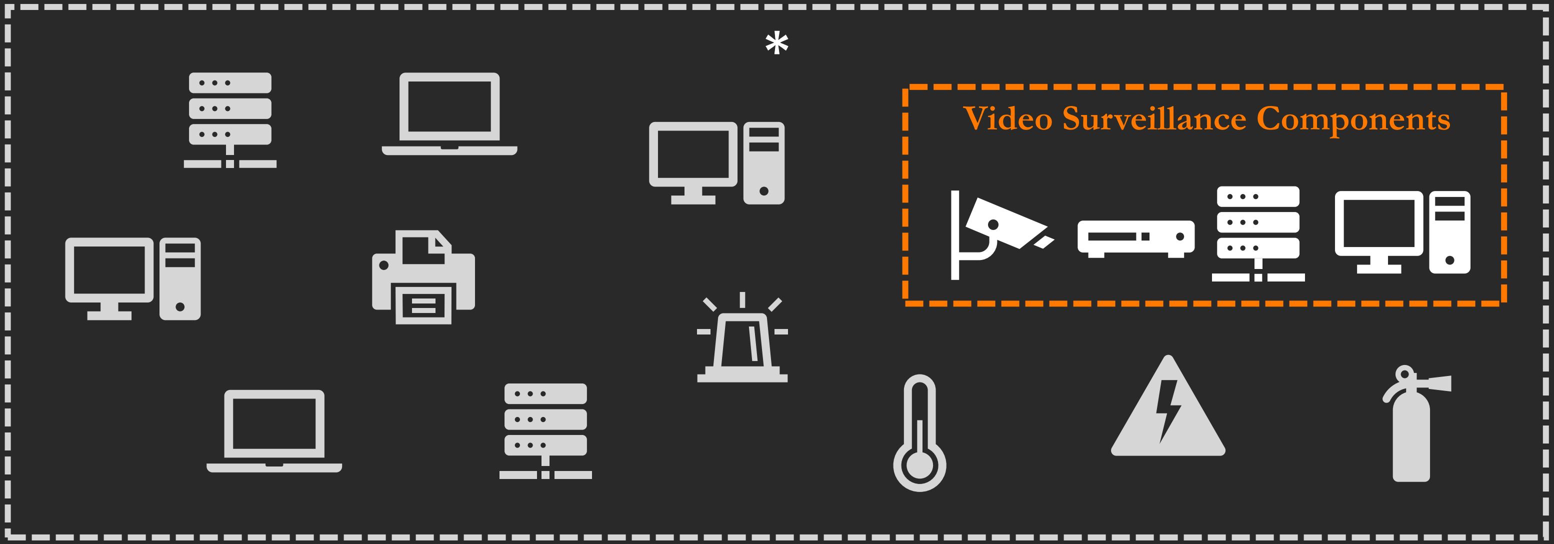


Network location (state of the art)

Network location (reality)



Network location (worse)



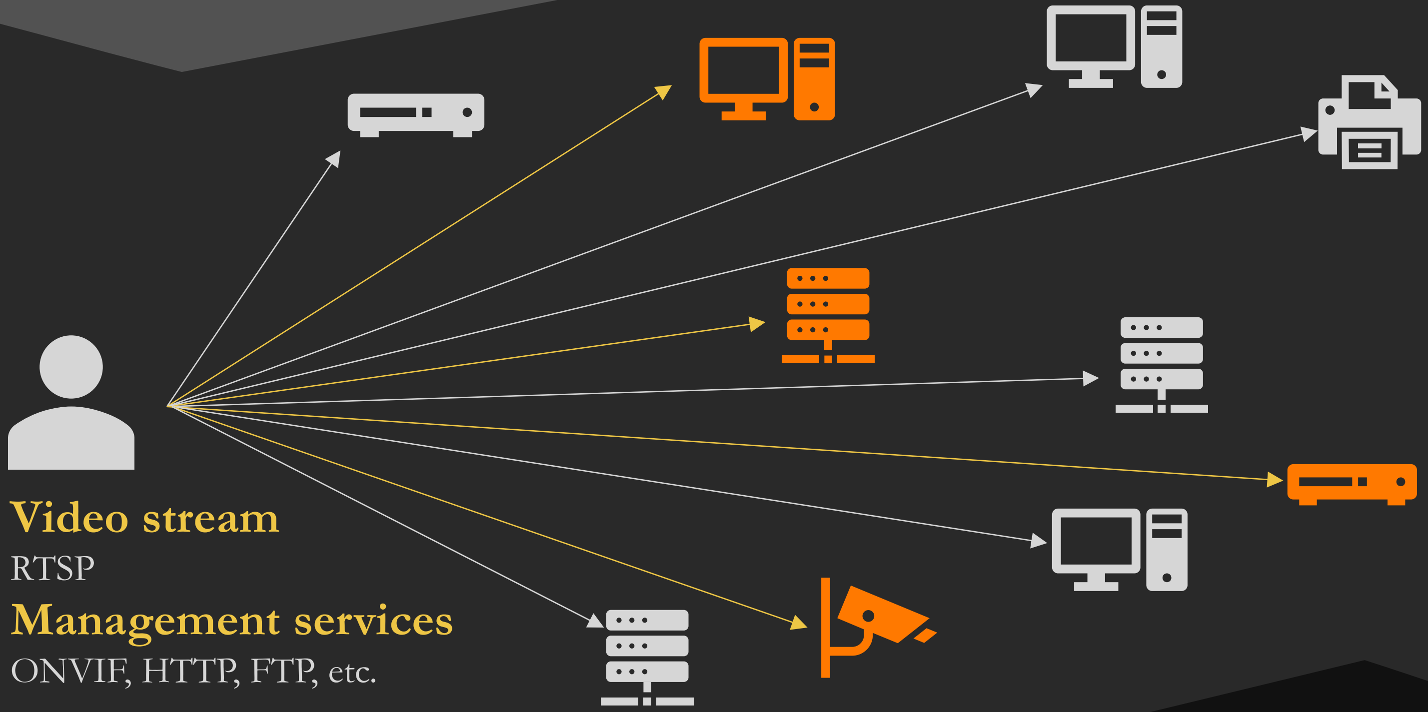
Video surveillance network (by trust zones)

Video surveillance network (reality)

Reconnaissance

Where video surveillance ??

Direct network scan



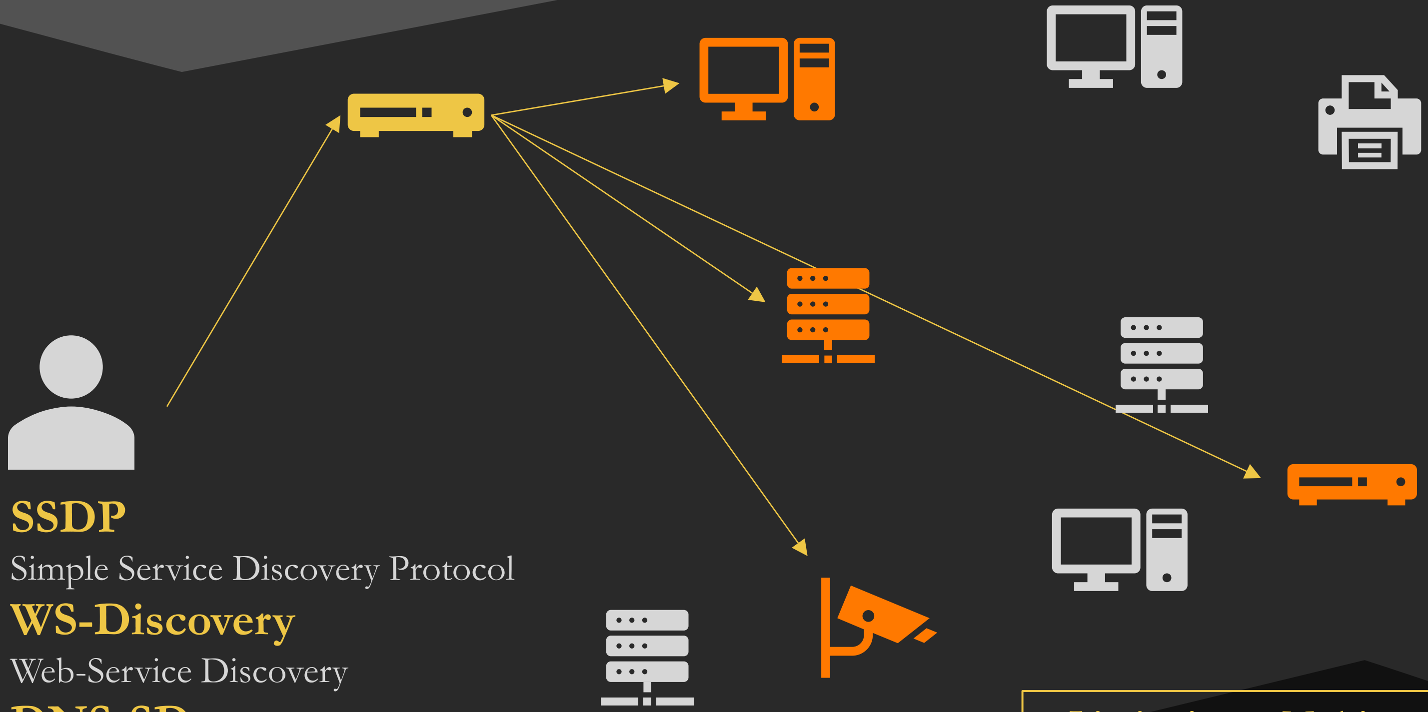
Video stream

RTSP

Management services

ONVIF, HTTP, FTP, etc.

Zeroconf discovery (multicast)



SSDP

Simple Service Discovery Protocol

WS-Discovery

Web-Service Discovery

DNS-SD

Limitations : Multicast routing

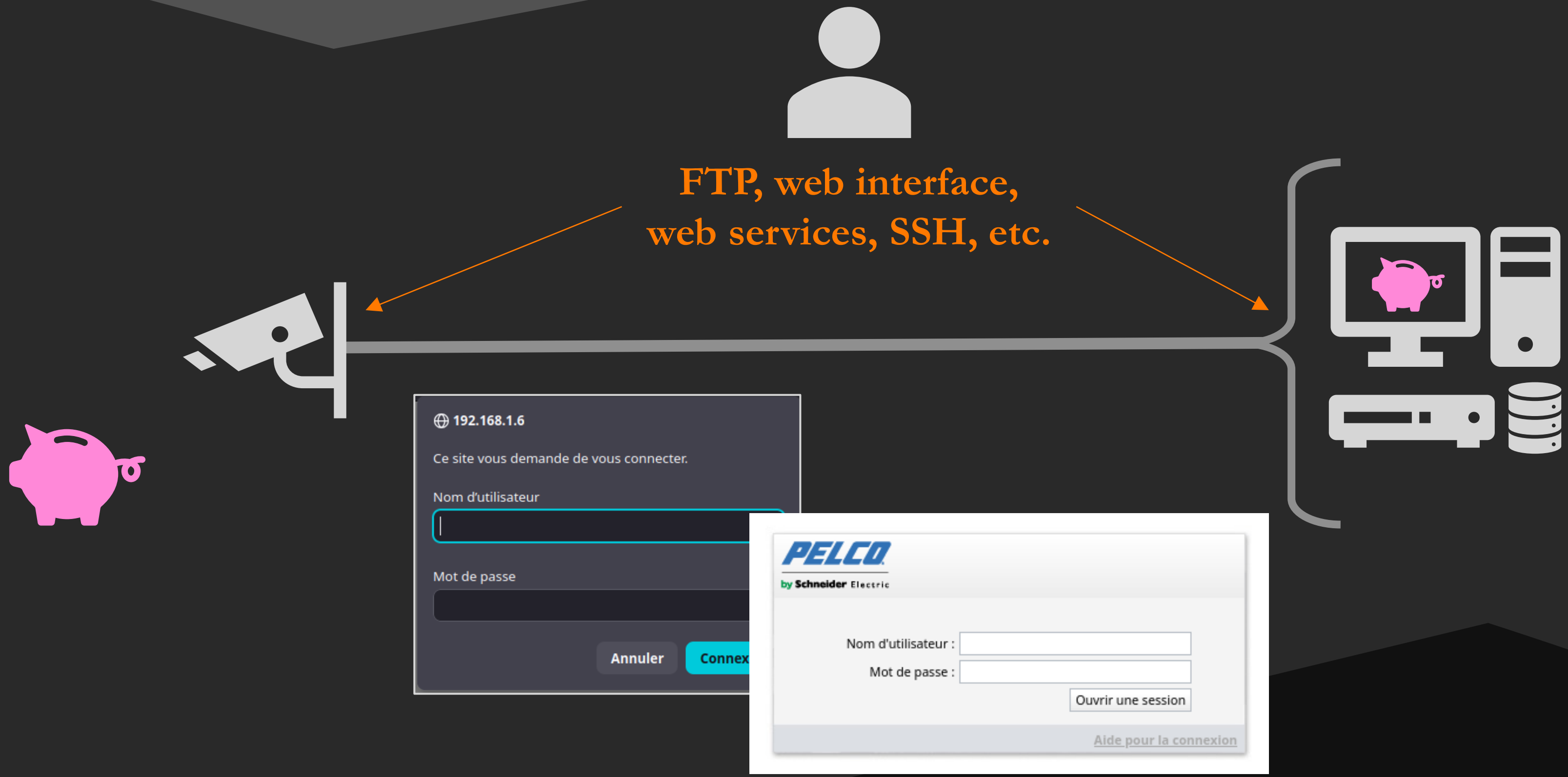
Some devices accept unicast as well

Find video surveillance components

Initial access

Fun with video streams

Management services



How to access administration services?

Default/weak credentials

Bruteforce

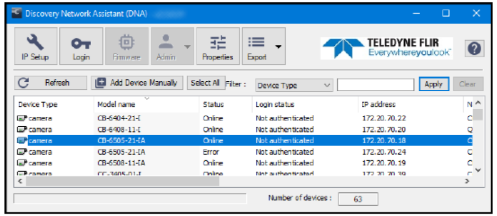
Eavesdropping

CVE exploit

c. In the DNA Discover List, verify that the camera's status is Online.

If this is the first time you are configuring the camera or if it is the first time after resetting the camera to its factory

automatically logs in to the camera with user name admin and its default password (admin).



IPVM

REPORTS / PUBLIC

IP Cameras Default Passwords Directory

Ethan Ace • Published Feb 09, 2018 14:33 PM

PUBLIC - This article do

Below is a directory of

Note: Change Default

CVE-2025-66174

There is an improper authentication vulnerability in some Hikvision DVR products. Due to the improper implementation of authentication for the serial port, an attacker with physical access could exploit this vulnerability by connecting to the affected products and run a series of commands.

Source: Hangzhou Hikvision Digital Technology Co., Ltd.

Max CVSS 6.8
EPSS Score 0.07%
Published 2025-12-19
Updated 2025-12-23

CVE-2025-66173

There is a privilege escalation vulnerability in some Hikvision DVR products. Due to the improper implementation of authentication for the serial port, an attacker with physical access could exploit this vulnerability by connecting to the affected products and gaining access to an unrestricted shell environment.

Source: Hangzhou Hikvision Digital Technology Co., Ltd.

Max CVSS 6.2
EPSS Score 0.09%
Published 2025-12-19
Updated 2025-12-23

CVE-2025-39247

There is an Access Control Vulnerability in some HikCentral Professional versions. This could allow an unauthenticated user to obtain the admin permission.

Max CVSS 8.6
EPSS Score 0.16%
Published 2025-08-29

FLIR Quasar CB-650 Series Quick Install Manual
https://ipvm.com/reports/ip-cameras-default-passwords-directory
Some CVE reported on components from the vendor Hikvision

ONVIF Web Service

`POST /onvif/device_service HTTP/1.1`

GetDeviceInformation

GetSystemSupportInformation

GetSystemBackup

GetSystemLog

GetStorageConfiguration

Set*

`POST /onvif/media_service HTTP/1.1`

GetProfile

GetStreamUri

ONVIF® http://www.onvif.org/ver10/device/wsdl

Operations

Port type **Device**

1. **AddIPAddressFilter**

   Description:

   This operation adds an IP filter address to a device. If the device supports device access control based on IP filtering rules (denied or accepted ranges of IP addresses), the device shall support adding of IP filtering addresses through the AddIPAddressFilter command.

   SOAP action:

   http://www.onvif.org/ver10/device/wsdl/AddIPAddressFilter

   Input:

   [AddIPAddressFilter]
   - **IPAddressFilter** [IPAddressFilter]
     - **Type** [IPAddressFilterType] - enum { 'Allow', 'Deny' }
     - **IPv4Address** - optional, unbounded; [PrefixedIPv4Address]
       - **Address** [IPv4Address]
         IPv4 address
       - **PrefixLength** [int]
         Prefix/submask length
     - **IPv6Address** - optional, unbounded; [PrefixedIPv6Address]
       - **Address** [IPv6Address]
         IPv6 address
       - **PrefixLength** [int]
         Prefix/submask length
     - **Extension** - optional; [IPAddressFilterExtension]

   Output:

   [AddIPAddressFilterResponse]

2. **AddScopes**

   Description:

   This operation adds new configurable scope parameters to a device. The scope parameters are used in the device discovery to match a probe message. The device shall support addition of discovery scope parameters through the AddScopes command.

   SOAP action:

   http://www.onvif.org/ver10/device/wsdl/AddScopes

   Input:

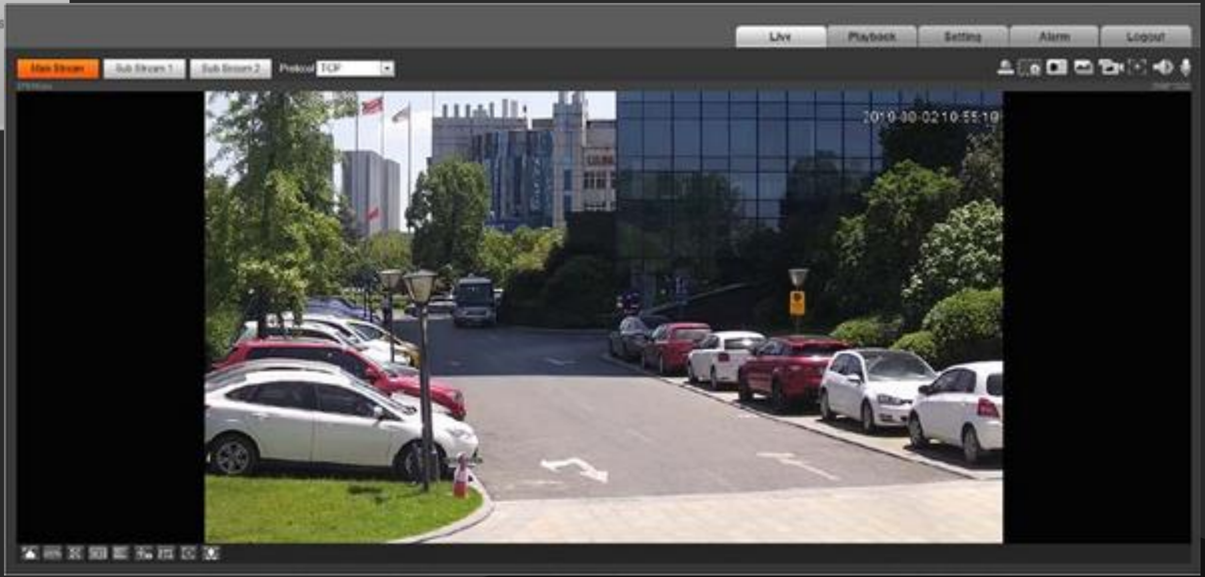
   [AddScopes]
   - **ScopeItem** - unbounded; [anyURI]
     Contains a list of new configurable scope parameters that will be added to the existing configurable scope.

   Output:

https://www.onvif.org/ver10/device/wsdl/devicemgmt.wsdl
https://www.onvif.org/ver10/media/wsdl/media.wsdl

Requires credentials if authentication is enabled on ONVIF (not always ☺)

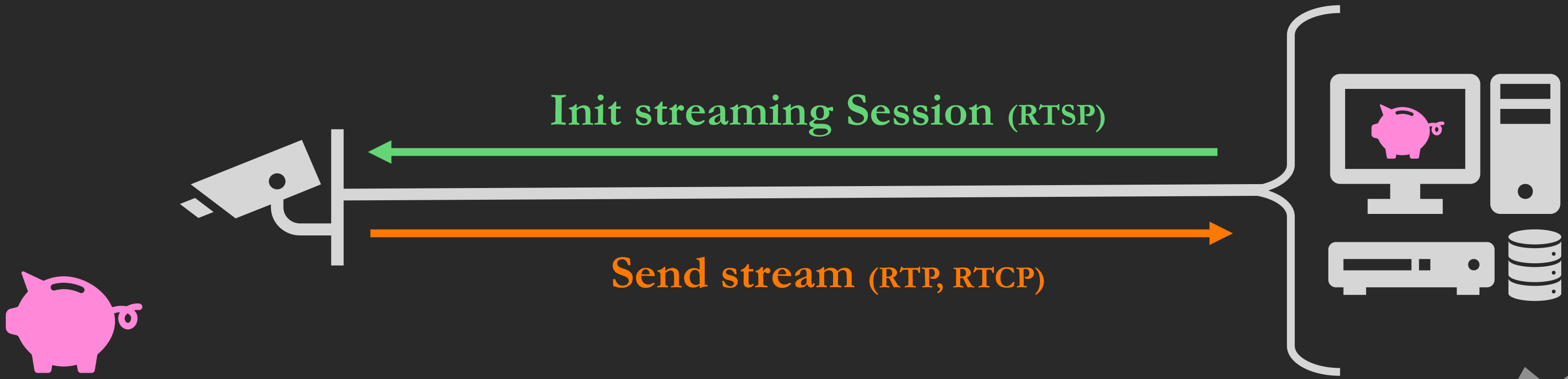
Live view on web interface



Dahua IPC-EB5541-M12-SA Operation Manual

RFC 7826

Real-Time Streaming Protocol (RTSP)



Also available
RTSPS
SRTP

TCP
UDP

What if we don't have RTSP credentials?

> *RTSP and HTTP share common authentication schemes […]. Servers SHOULD implement both the **Basic** [RFC7617] and the **Digest** [RFC7616] authentication schemes. (RFC 7826)*

No authentication

Default credentials

Bruteforce

```
Cameradar – vdev (unknown)

Steps
                                        100% 6/6 complete
✓ Scan targets
✓ Attack routes
✓ Detect authentication
✓ Attack credentials
✗ Validate streams
✓ Summary

Logs
[INFO] Scan targets: Scanning targets for RTSP streams
[INFO] Scan targets: Found 2 RTSP streams
[INFO] Scan targets: Scan complete
[INFO] Attack routes: Attacking RTSP routes
[INFO] Attack routes: Route found for 192.168.1.13:554 -> stream1
[INFO] Attack routes: Finished route attacks
[INFO] Detect authentication: Detecting authentication methods
[INFO] Detect authentication: Detected unknown authentication for 192.168.1.12:5543
[INFO] Detect authentication: Detected no authentication for 192.168.1.13:554
[INFO] Detect authentication: Authentication detection complete
[INFO] Attack credentials: Attacking credentials
[INFO] Attack credentials: Credentials found for 192.168.1.12:5543
[INFO] Attack credentials: Credentials found for 192.168.1.13:554
[INFO] Attack credentials: Credential attacks complete
[INFO] Validate streams: Validating streams
[INFO] Validate streams: Stream validated for 192.168.1.13:554
[ERROR] Validate streams: performing describe request at "rtsp://192.168.1.12:5543/": bad status code: 404 (Not Found)

Summary - Streams (1 accessible / 2 total)
```

Target	Device	Auth	Routes	Credentials	Available	RTSP URL	Admin
192.168.1.13:554	–	none	stream1	:	yes	rtsp://192.168.1.13:554/stream1	http://192.168.1.13/
192.168.1.12:5543	–	unknown(	–	:	no	–	http://192.168.1.12/

https://github.com/Ullaakut/cameradar

RFC 7826

Real-Time Streaming Protocol (RTSP)

rtsp://<camera_ip>:554/axis-media/media.amp

rtsp://<camera_ip>:554/stream1

rtsp://<camera_ip>:5543/7aad7e5c56cb38a15a5a76bc0e74f60e/live/channel0

rtsp://<camera_ip>:554/cam/realmonitor?channel=<CHANNEL>&subtype=1

rtsp://<camera_ip>:554/video.h264

rtsp://<camera_ip>:554 /cam1/onvif-h264

How to find the RTSP stream URI?

Ask the device

```
├─ Stream information
│  ├─ PROFILE_17345
│  │  ├─ Stream URI : rtsp://192.168.1.12:5543/7aad7e5c56cb38a15a5a76bc0e74f60e/live/channel0
│  │  ├─ Snapshot URI : http://192.168.1.12:8000/snapshot/PROFILE_17345
│  ├─ PROFILE_17347
│  │  ├─ Stream URI : rtsp://192.168.1.12:5543/7aad7e5c56cb38a15a5a76bc0e74f60e/live/channel1
│  │  ├─ Snapshot URI : http://192.168.1.12:8000/snapshot/PROFILE_17347
```

User manual

```
├─ Stream information
│  ├─ 0
│  │  ├─ Stream URI : rtsp://192.168.1.13/stream1
│  │  ├─ Snapshot URI : http://192.168.1.13/jpeg
│  ├─ 1C492DEB0744
│  │  ├─ Stream URI : rtsp://192.168.1.13/stream1
│  │  ├─ Snapshot URI : http://192.168.1.13/jpeg
│  ├─ B0CDD0721D48
│  │  ├─ Stream URI : rtsp://192.168.1.13/stream1
```

Online databases

Bruteforce

Requires credentials if authentication is enabled on ONVIF (not always ☺)

How to find the RTSP stream URI?

Ask the device

User manual

Online databases

Bruteforce

alhua

Operation Manual

Parameter	Description
RTSP Port	• Real time streaming protocol port, and the value is 554 by default. If you play live view with QuickTime, VLC or Blackberry smart phone, the following URL format is available. • When the URL format requiring RTSP, you need to specify channel number and bit stream type in the URL, and also user name and password if needed. • When playing live view with Blackberry smart phone, you need to turn off the audio, and then set the codec mode to H.264B and resolution to CIF. URL format example: rtsp://username:password@ip:port/cam/realmonitor?channel=1&subtype=0 Among that: • Username: The user name, such as admin. • Password: The password, such as admin. • IP: The device IP, such as 192.168.1.112. • Port: Leave it if the value is 554 by default. • Channel: The channel number, which starts from 1. For example, if you are using channel 2, then the channel=2. • Subtype: The bit stream type; 0 means main stream (Subtype=0) and 1 means sub stream (Subtype=1). Example: If you require the sub stream of channel 2 from a certain device, then the URL should be: rtsp://admin:admin@10.12.4.84:554/cam/realmonitor?channel=2&subtype=1 If user name and password are not needed, then the URL can be: rtsp://ip:port/cam/realmonitor?channel=1&subtype=0

FLIR

RTSP - Display and record a video stream (Automation Cameras)

Updated Date
20/12/2024 07.01 PM

How do I see or record the RTSP video stream from my camera?
What RTSP URL should I use?

RTSP URL's

Regardless of software used, you need to specify the RTSP video stream address to capture the video stream from a camera.

The RTSP URL needs to have the camera IP address and a format at a minimum. For example:
`rtsp://192.168.14.2/avc`

Dahua IPC-EB5541-M12-SA Operation Manual
https://flir.custhelp.com

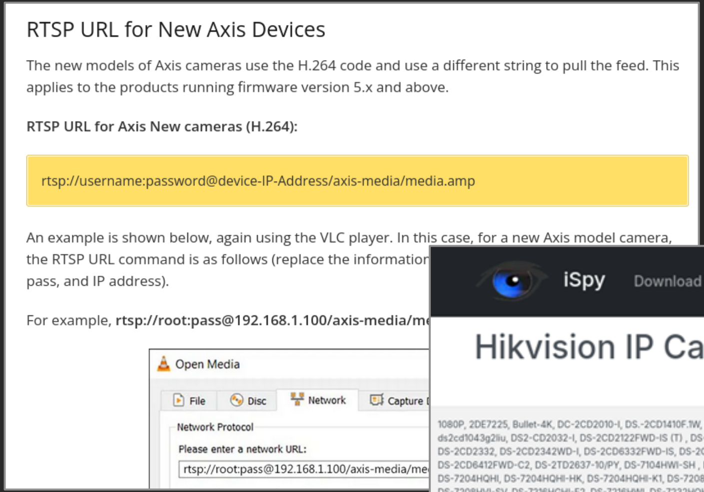
How to find the RTSP stream URI?

Ask the device

User manual

Online databases

Bruteforce



https://securitycamcenter.com/rtsp-commands-axis-cameras/
https://www.ispyconnect.com/camera/hikvision

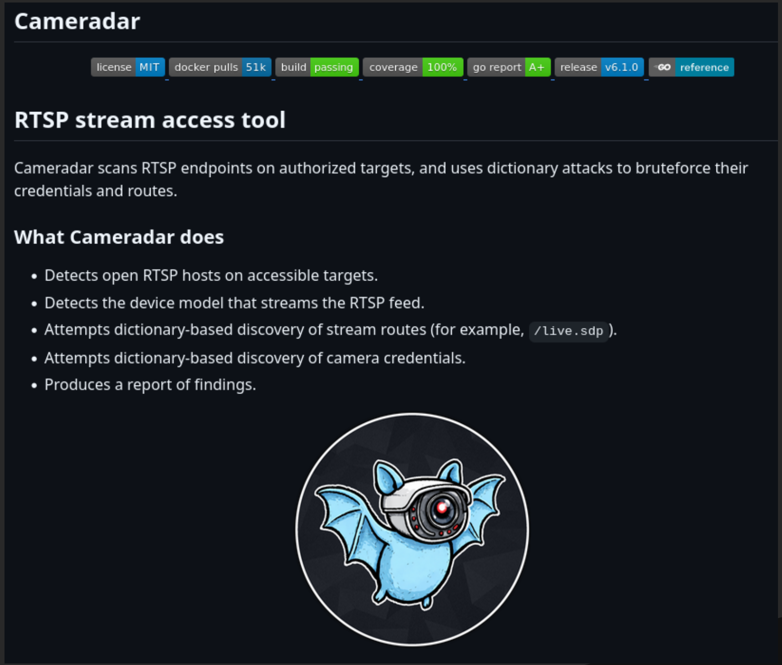
How to find the RTSP stream URI?

Ask the device

User manual

Online databases

Bruteforce



Cameradar

license MIT | docker pulls 51k | build passing | coverage 100% | go report A+ | release v6.1.0 | GO reference

RTSP stream access tool

Cameradar scans RTSP endpoints on authorized targets, and uses dictionary attacks to bruteforce their credentials and routes.

What Cameradar does

- Detects open RTSP hosts on accessible targets.
- Detects the device model that streams the RTSP feed.
- Attempts dictionary-based discovery of stream routes (for example, `/live.sdp`).
- Attempts dictionary-based discovery of camera credentials.
- Produces a report of findings.

```
paths = [
    "/onvif1",
    "/onvif2",
    "/live",
    "/h264",
    "/0",
    "/H264",
    "/live",
    "/livestream",
    "/media",
    "/mpeg4",
    "/multicaststream",
    "/onvif-media/media.amp",
    "/onvif/live/2",
    "/onvif1",
    "/onvif2",
    "/rtsph264",
    "/stream1",
    "/stream2",
    "/video",
    "/video1",
    "/1/stream1",
    ...
]
```

https://github.com/Ullaakut/cameradar

Find video surveillance components

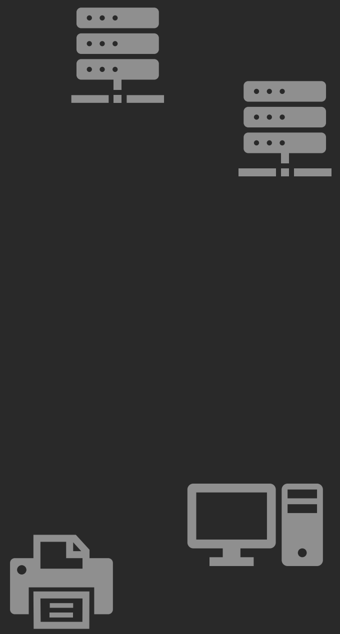
Initial access

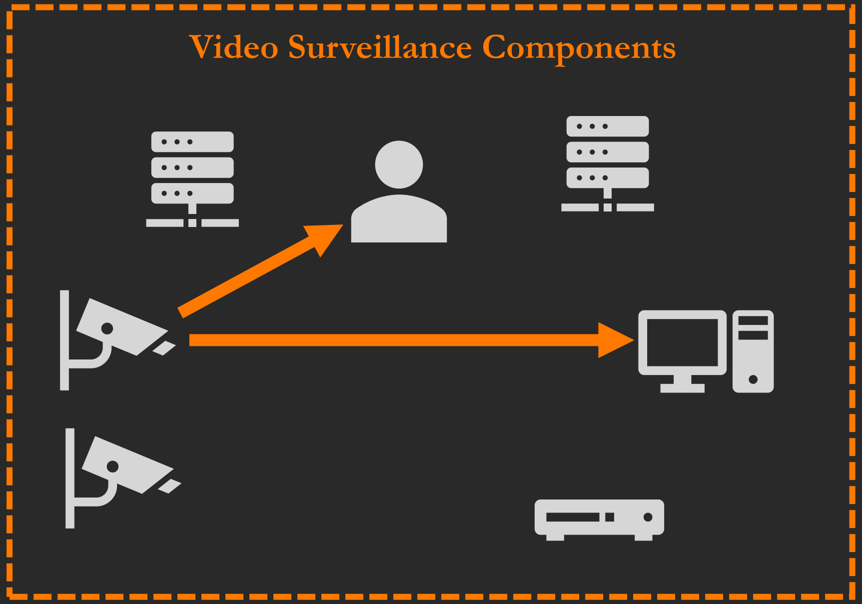
Fun with video streams

Aha.

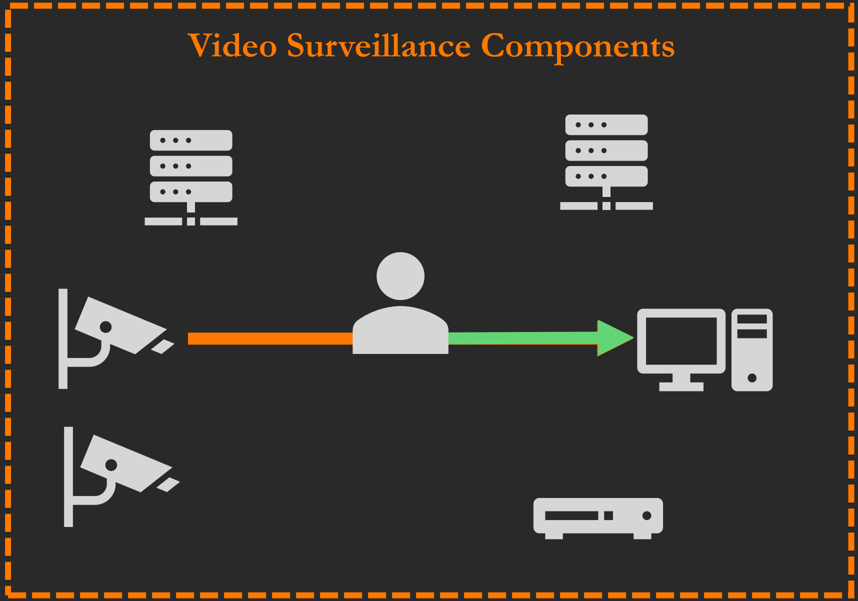
Shodan results for search « rtsp » on 2026-02-27

The pentester’s view





The pentester’s view



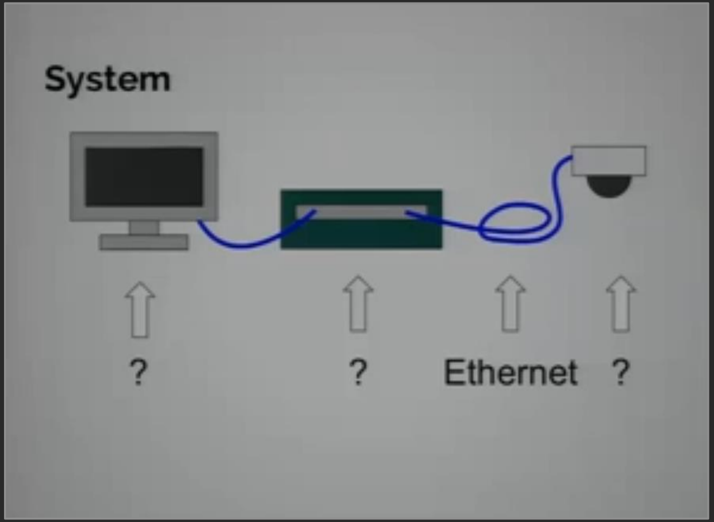
Do not do this in sensitive environments

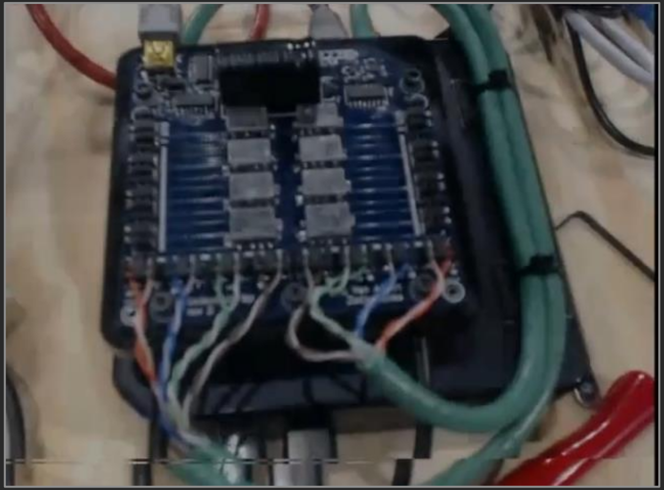
1. Intercept the video stream
2. View the intercepted stream
3. Tamper with the video stream

Previous attempts

Speed (1994)

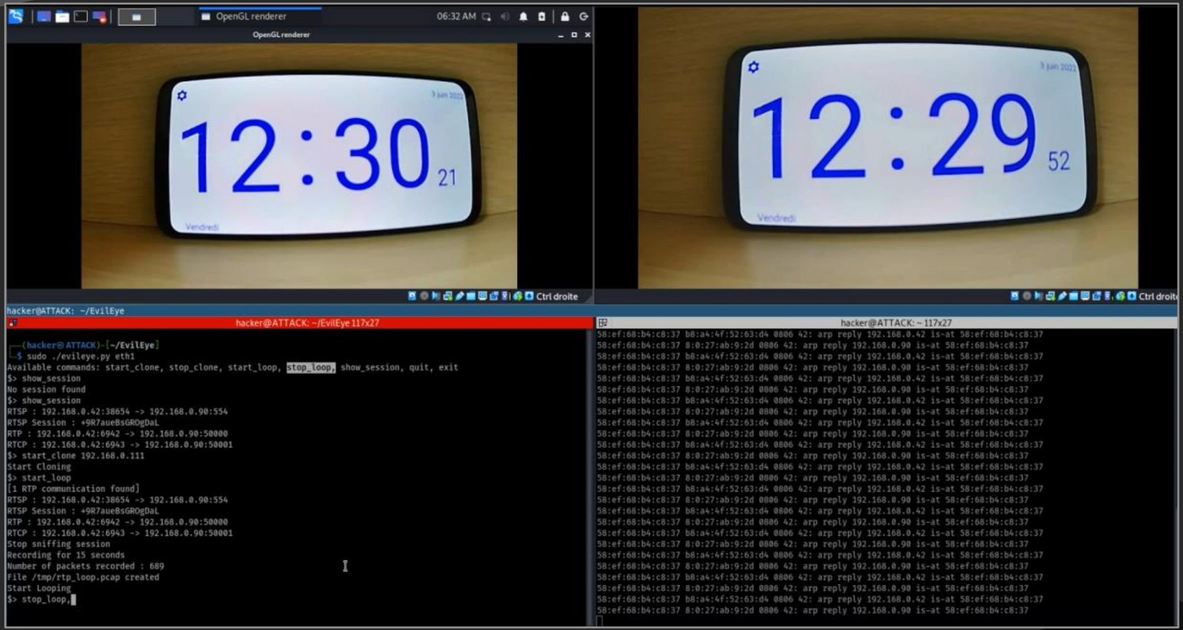
Previous attempts





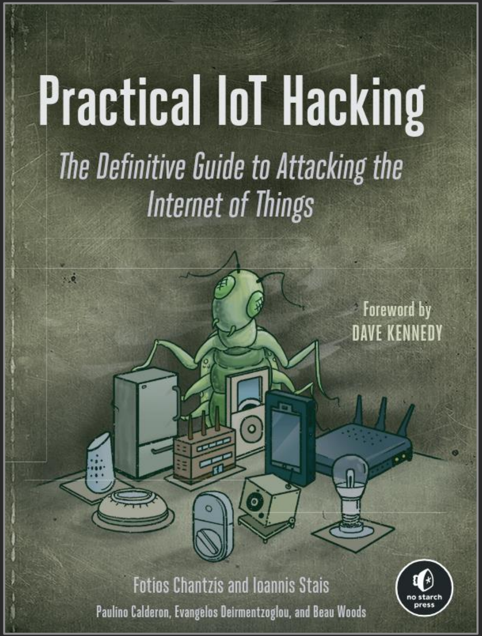
Looping Surveillance Cameras through Live Editing,
Van Albert and Banks, DEFCON 23, 2015

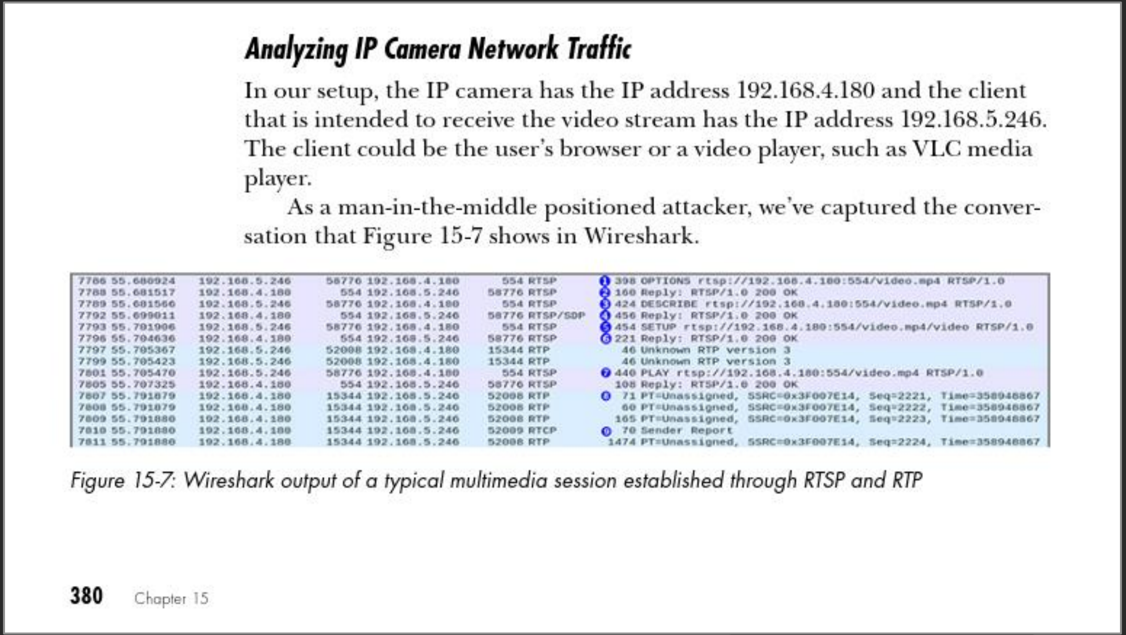
Previous attempts



EvilEye
Nicolas Tarriol and Claire Vacherot, 2020

Previous attempts





Analyzing IP Camera Network Traffic

In our setup, the IP camera has the IP address 192.168.4.180 and the client that is intended to receive the video stream has the IP address 192.168.5.246. The client could be the user's browser or a video player, such as VLC media player.

As a man-in-the-middle positioned attacker, we've captured the conversation that Figure 15-7 shows in Wireshark.

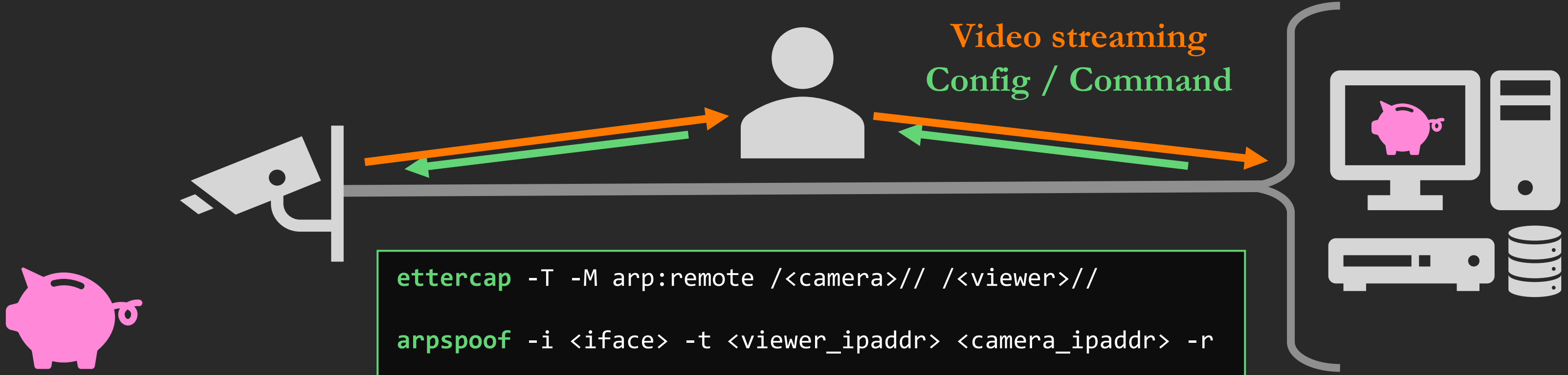
7786	55.680924	192.168.5.246	58776	192.168.4.180	554	RTSP	1	398	OPTIONS rtsp://192.168.4.180:554/video.mp4 RTSP/1.0
7788	55.681517	192.168.4.180	554	192.168.5.246	58776	RTSP	2	160	Reply: RTSP/1.0 200 OK
7789	55.681566	192.168.5.246	58776	192.168.4.180	554	RTSP	3	424	DESCRIBE rtsp://192.168.4.180:554/video.mp4 RTSP/1.0
7792	55.699011	192.168.4.180	554	192.168.5.246	58776	RTSP/SDP	4	456	Reply: RTSP/1.0 200 OK
7793	55.701906	192.168.5.246	58776	192.168.4.180	554	RTSP	5	454	SETUP rtsp://192.168.4.180:554/video.mp4/video RTSP/1.0
7796	55.704636	192.168.4.180	554	192.168.5.246	58776	RTSP	6	221	Reply: RTSP/1.0 200 OK
7797	55.705367	192.168.5.246	52008	192.168.4.180	15344	RTP		46	Unknown RTP version 3
7799	55.705423	192.168.5.246	52008	192.168.4.180	15344	RTP		46	Unknown RTP version 3
7801	55.705470	192.168.5.246	58776	192.168.4.180	554	RTSP	7	440	PLAY rtsp://192.168.4.180:554/video.mp4 RTSP/1.0
7805	55.707325	192.168.4.180	554	192.168.5.246	58776	RTSP		108	Reply: RTSP/1.0 200 OK
7807	55.791879	192.168.4.180	15344	192.168.5.246	52008	RTP	8	71	PT=Unassigned, SSRC=0x3F007E14, Seq=2221, Time=358948867
7808	55.791879	192.168.4.180	15344	192.168.5.246	52008	RTP		60	PT=Unassigned, SSRC=0x3F007E14, Seq=2222, Time=358948867
7809	55.791880	192.168.4.180	15344	192.168.5.246	52008	RTP		165	PT=Unassigned, SSRC=0x3F007E14, Seq=2223, Time=358948867
7810	55.791880	192.168.4.180	15344	192.168.5.246	52009	RTCP	9	70	Sender Report
7811	55.791880	192.168.4.180	15344	192.168.5.246	52008	RTP		1474	PT=Unassigned, SSRC=0x3F007E14, Seq=2224, Time=358948867

Figure 15-7: Wireshark output of a typical multimedia session established through RTSP and RTP

380 Chapter 15

Practical IoT Hacking
Fotios Chantzis, Ioannis Stais, Paulino Calderon, Evangelos Deirlentzoglou, Beau Woods

1. Intercept the video stream

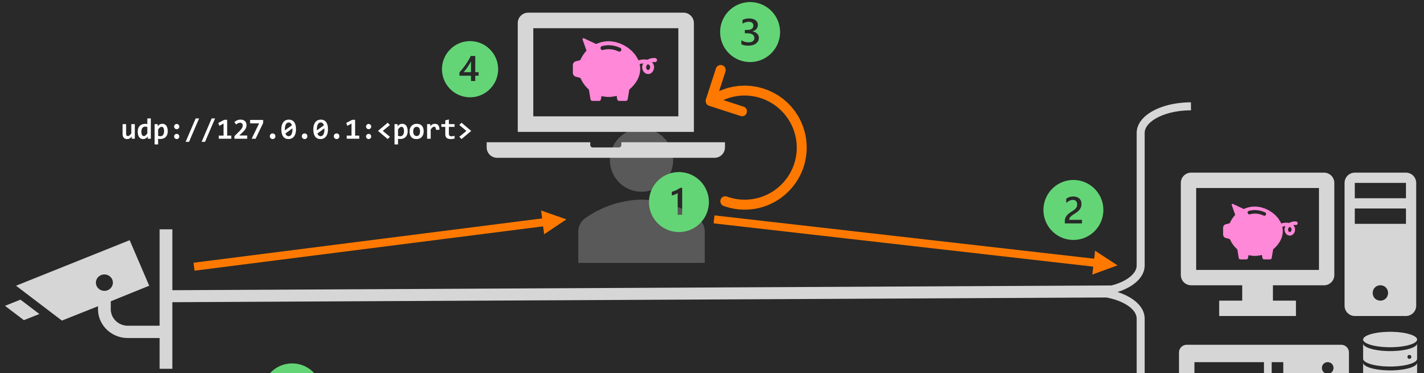



```
ettercap -T -M arp:remote /<camera>// /<viewer>//

arpspoof -i <iface> -t <viewer_ipaddr> <camera_ipaddr> -r

...
```

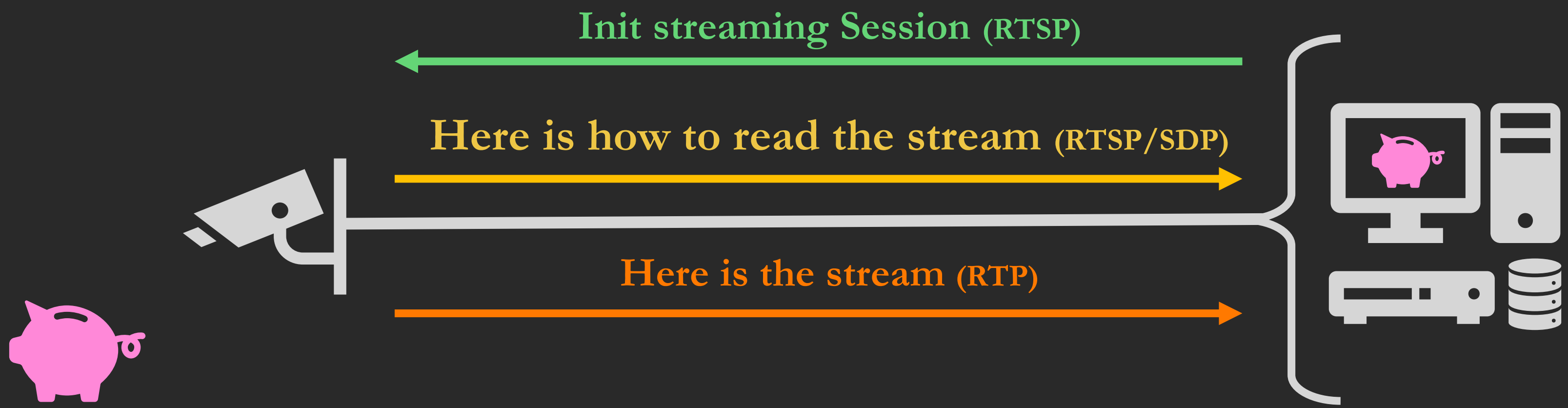
2. View the intercepted stream



Our choice:
NFQUEUES

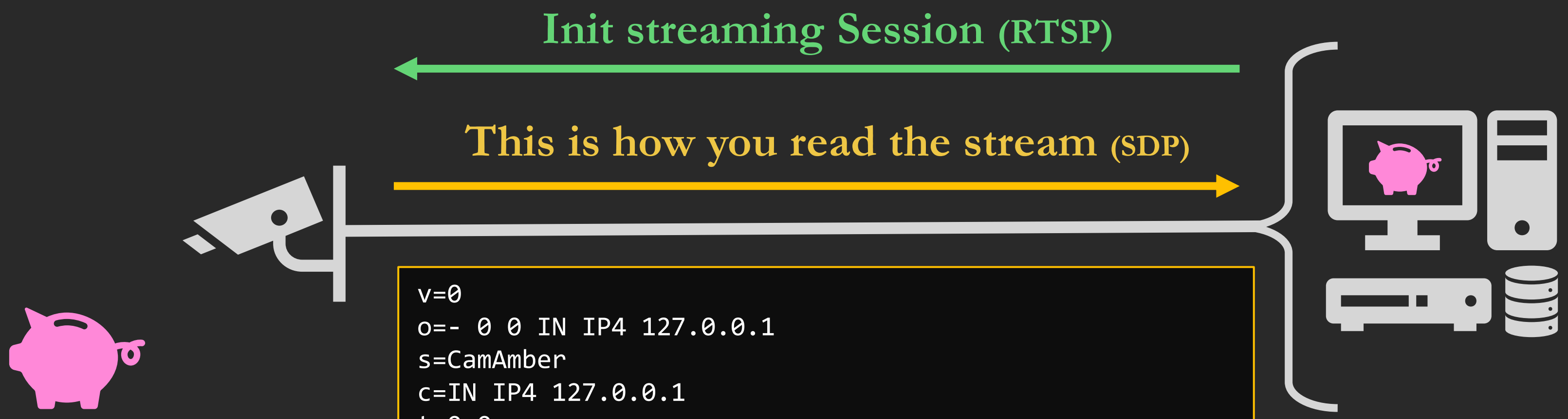
1. Duplicate stream
2. Forward original packet to destination
3. Redirect duplicate on local socket
4. Open network stream on media player

RTSP session initialization



RFC 8866 (SDP) and many more

Session Description Protocol (SDP)




```
v=0
o=- 0 0 IN IP4 127.0.0.1
s=CamAmber
c=IN IP4 127.0.0.1
t=0 0
m=video 0 RTP/AVP 96
a=rtpmap:96 H264/90000
a=fmtp:96 packetization-mode=1; sprop-parameter-
sets=Z2QAKawbGoBQBb/wFuAgICgAAB9AAAdTB0MAAX14AAB3NZXeX
GhgAC+vAAAO5rK7y4U=,aO44MA==; profile-level-id=640029
```

Is this cheating?

Init RTSP + SDP

```
$> show_session
No session found
$> show_session
RTSP : 192.168.0.42:38654 -> 192.168.0.90:554
RTSP Session : +9R7aueBsGROgDaL
RTP : 192.168.0.42:6942 -> 192.168.0.90:50000
RTCP : 192.168.0.42:6943 -> 192.168.0.90:50001
$> start_clone 192.168.0.111
Start Cloning
$> start_loop
```

Init RTSP

SDP

7786	55.680924	192.168.5.246	58776	192.168.4.180	554	RTSP	1	398	OPTIONS rtsp://192.168.4.180:554/video.mp4 RTSP/1.0
7788	55.681517	192.168.4.180	554	192.168.5.246	58776	RTSP	2	160	Reply: RTSP/1.0 200 OK
7789	55.681566	192.168.5.246	58776	192.168.4.180	554	RTSP	3	424	DESCRIBE rtsp://192.168.4.180:554/video.mp4 RTSP/1.0
7792	55.699011	192.168.4.180	554	192.168.5.246	58776	RTSP/SDP	4	456	Reply: RTSP/1.0 200 OK
7793	55.701906	192.168.5.246	58776	192.168.4.180	554	RTSP	5	454	SETUP rtsp://192.168.4.180:554/video.mp4/video RTSP/1.0
7796	55.704636	192.168.4.180	554	192.168.5.246	58776	RTSP	6	221	Reply: RTSP/1.0 200 OK
7797	55.705367	192.168.5.246	52008	192.168.4.180	15344	RTP		46	Unknown RTP version 3
7799	55.705423	192.168.5.246	52008	192.168.4.180	15344	RTP		46	Unknown RTP version 3
7801	55.705470	192.168.5.246	58776	192.168.4.180	554	RTSP	7	440	PLAY rtsp://192.168.4.180:554/video.mp4 RTSP/1.0
7805	55.707325	192.168.4.180	554	192.168.5.246	58776	RTSP		108	Reply: RTSP/1.0 200 OK
7807	55.791879	192.168.4.180	15344	192.168.5.246	52008	RTP	8	71	PT=Unassigned, SSRC=0x3F007E14, Seq=2221, Time=358948867
7808	55.791879	192.168.4.180	15344	192.168.5.246	52008	RTP		60	PT=Unassigned, SSRC=0x3F007E14, Seq=2222, Time=358948867
7809	55.791880	192.168.4.180	15344	192.168.5.246	52008	RTP		165	PT=Unassigned, SSRC=0x3F007E14, Seq=2223, Time=358948867
7810	55.791880	192.168.4.180	15344	192.168.5.246	52009	RTCP	9	70	Sender Report
7811	55.791880	192.168.4.180	15344	192.168.5.246	52008	RTP		1474	PT=Unassigned, SSRC=0x3F007E14, Seq=2224, Time=358948867

Figure 15-7: Wireshark output of a typical multimedia session established through RTSP and RTP

Practical IoT Hacking
EvilEye

What if we don't have the SDP?

Init a RTSP session to retrieve a valid SDP

Requires credentials (if any)

Extract info from video data in frames

Theoretical

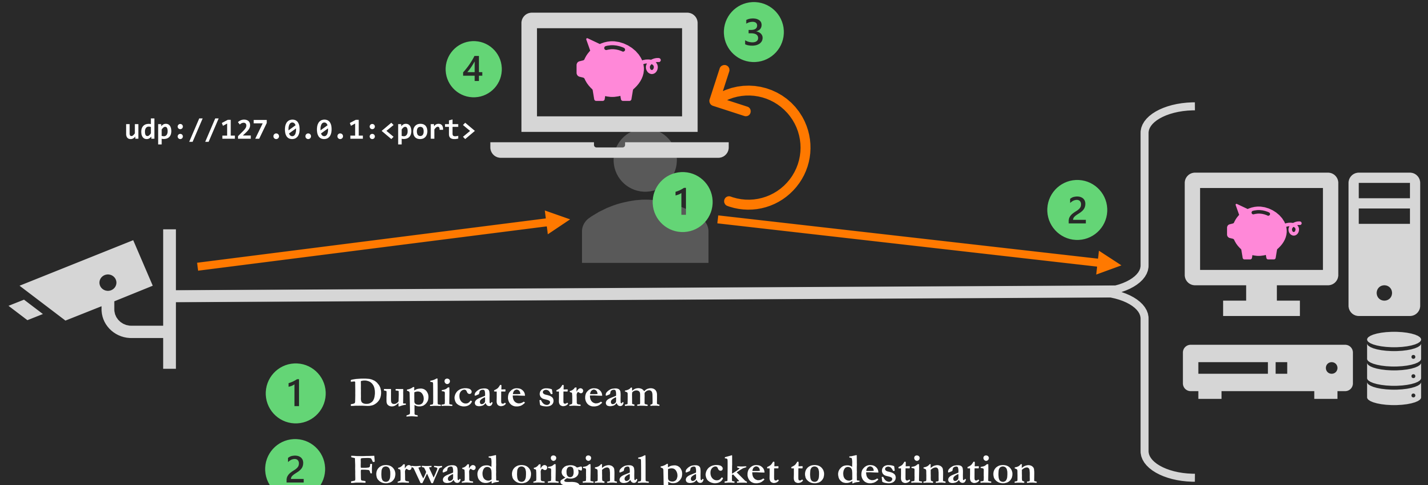
Forge a SDP file

Standard for some formats (e.g. **MPEG**)

Low chances of success for **H.264** / **H.265**

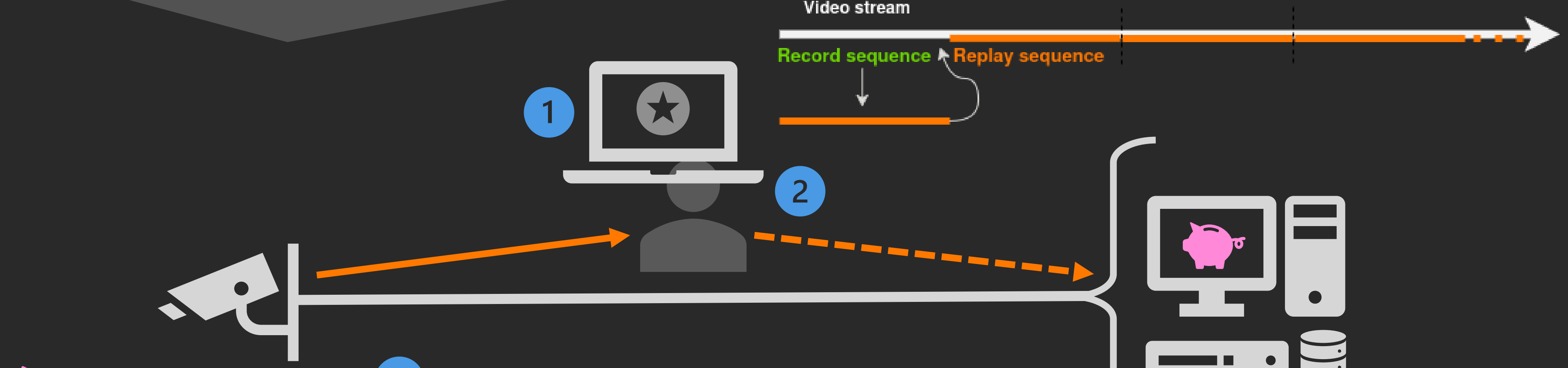
```
v=0
o=- 0 0 IN IP4 127.0.0.1
s=CamAmber
c=IN IP4 127.0.0.1
t=0 0
m=video 0 RTP/AVP 96
a=rtpmap:96 H264/90000
a=fmtp:96 packetization-mode=1; sprop-parameter-
sets=Z2QAKawbGoBQBb/wFuAgICgAAB9AAAdTB0MAAX14AAB3NZXeX
GhgAC+vAAAO5rK7y4U=,aO44MA==; profile-level-id=640029
```

DEMO TIME



1. Duplicate stream
2. Forward original packet to destination
3. Redirect duplicate on local socket
4. Open network stream on media player

3. Tamper with the video stream

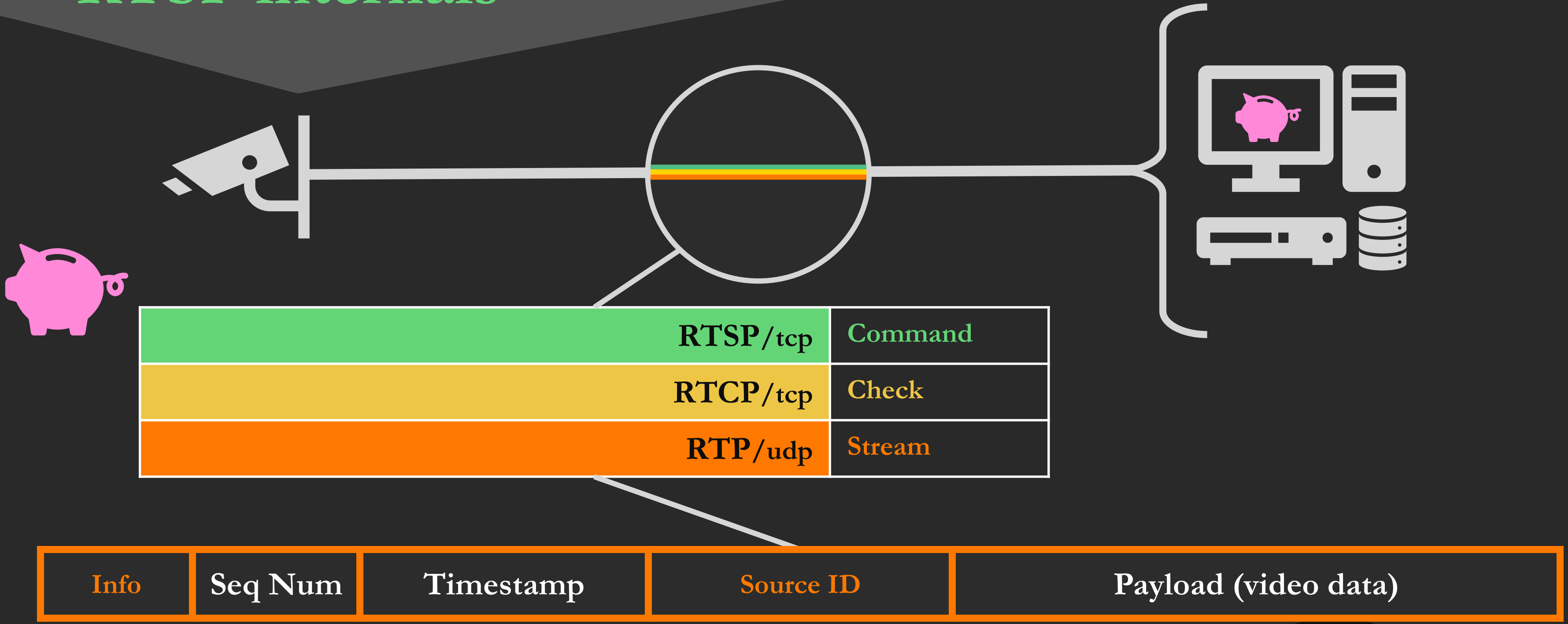


1. Record original stream sequence
2. Replace original stream

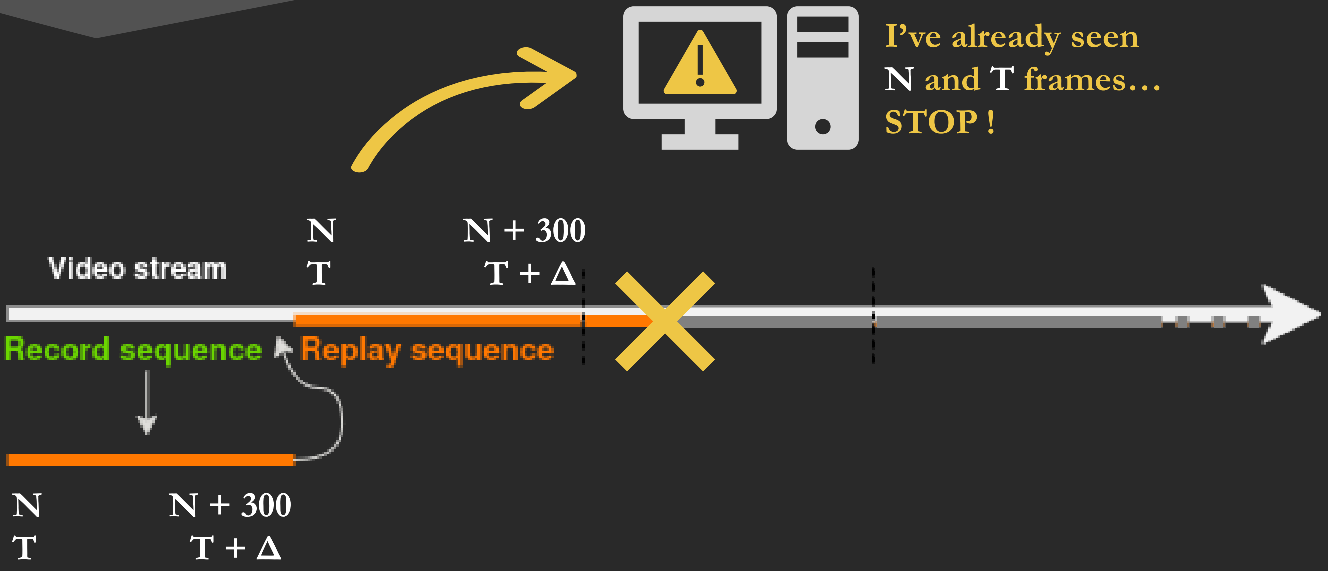
★ View original stream locally (optional)

RFC 3550 et al.

RTSP internals

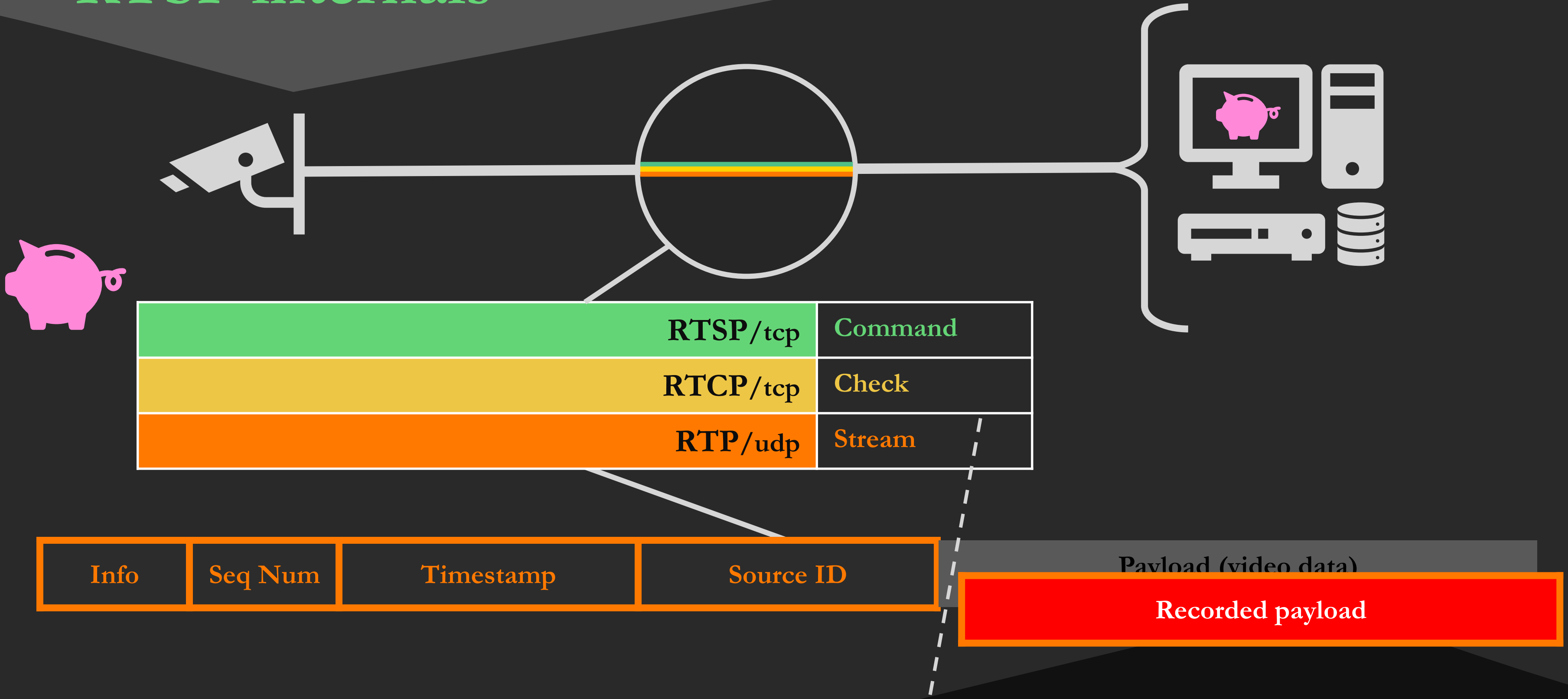


RTSP internals

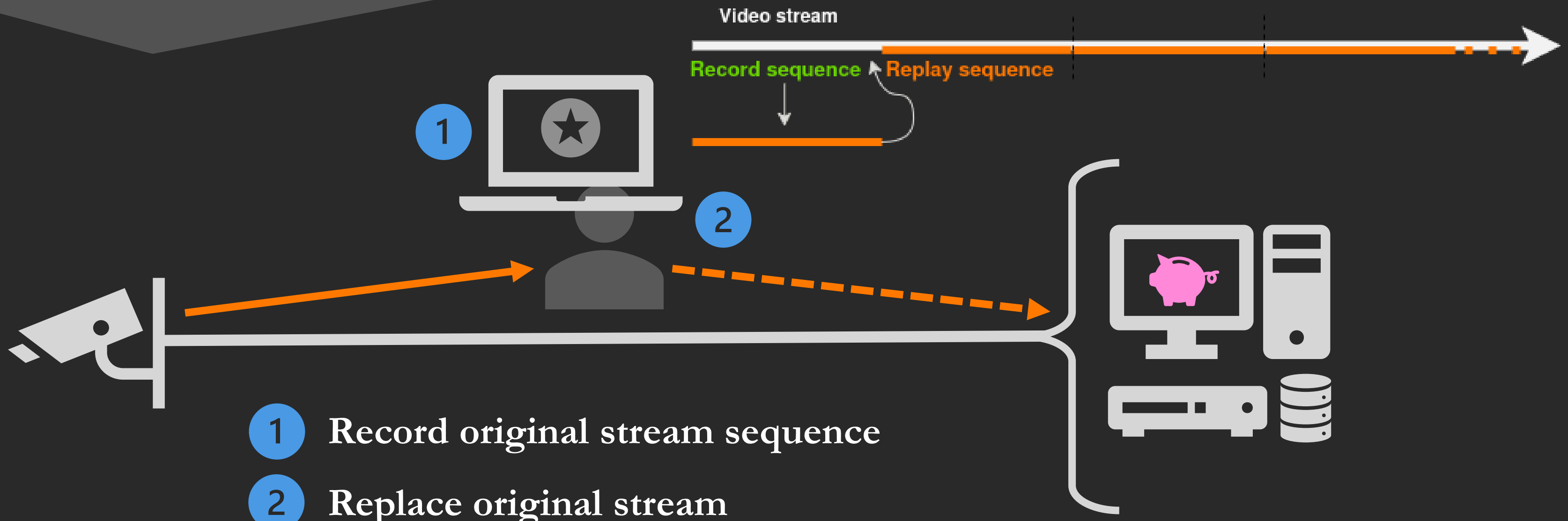


RFC 3550 et al.

RTSP internals



DEMO TIME

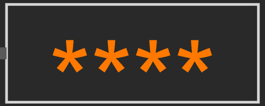


1. Record original stream sequence
2. Replace original stream
- ★ View original stream locally (optional)

Remediation

Network segmentation

Configuration hardening



Upgrade to RTSPS/SRTP

Conclusion

Not so trivial but not so complicated either

Toolkit : CamAmber

Several other leads

Better use of ONVIF Get/Set functions

SAP (Service Announcement Protocol, RFC 2974)

RTP special blocks (PPS/SPS, RFC 7798)

Let’s talk about it!

CAM AMBER

Orange-Cyberdefense/cam-amber

camamber-discover.py SSDP/WS-Discovery	camamber-onvif.py ONVIF discovery
camamber-sdp.py SDP retrieval	camamber.c Intercept and replace stream

Orange Cyberdefense

Thank you!

Claire Vacherot

github.com/claire-lex

claire.vacherot@orangecyberdefense.com

SECURITY FEST